COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.1 · Security Policies

Mestre CyberSec · **Lesson 5.1 — Security Policies** (11:02) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Policies = o QUE deve ser feito (top-level); Standards = o HOW (mais técnico); Procedures = o passo-a-passo. AUP (acceptable use policy): o que o usuário pode fazer. BCP (business continuity plan)/DRP (disaster recovery plan) = continuidade do negócio.

💡 Key Exam Highlights & Critical Concepts

- Policy: o 'o quê'. Standard: o 'como'. Procedure: o passo-a-passo
- AUP: o que o usuário PODE fazer com recurso corporativo

🎯 Exam Tips & Typical CompTIA Scenarios

- 'high-level document stating what to protect'=policy

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.1 — Security Policies)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Policy (N/A)

A high-level, mandatory document that states what an organization wants to protect and its overall security objectives; it does not specify technical implementation.

⚠️ ***Exam Trap:*** *Se a questão pedir 'high-level document stating what to protect', a resposta é policy. Não confunda com standard (como) ou procedure (passo a passo).*

• Standard (N/A)

A mandatory, technical document that defines specific requirements, rules, or baselines for implementing a policy.

⚠️ ***Exam Trap:*** *Standard = 'como' técnico e mensurável. Se a questão citar configuração específica, criptografia AES-256 ou senha mínima, provavelmente é standard.*

• Procedure (N/A)

A mandatory, step-by-step document that describes exactly how to perform a specific task or process in accordance with policies and standards.

⚠️ ***Exam Trap:*** *Procedure = passo a passo operacional. Se a questão descreve uma sequência de ações a serem executadas, é procedure.*

• Guidelines (N/A)

Non-mandatory recommendations or best practices that help users and administrators comply with policies and standards.

⚠️ ***Exam Trap:*** *Guidelines são recomendadas, mas não obrigatórias. Se a questão disser 'best practice' ou 'não obrigatório', não é policy nem standard.*

• Acceptable Use Policy (AUP)

A policy that defines what users are permitted and not permitted to do with corporate IT resources, including email, internet, and devices.

⚠️ ***Exam Trap:*** *AUP = o que o usuário PODE fazer com recurso corporativo. Frequentemente exige assinatura ou ciência do funcionário. Não é BCP nem DRP.*

• **Business Continuity Plan (BCP)**

A plan that ensures critical business functions can continue during and after a disruption, focusing on the entire organization's resilience.

⚠️ ***Exam Trap:*** *BCP = continuidade do negócio como um todo. Se a questão fala em manter operações críticas durante um desastre, é BCP. DRP é recuperação de TI.*

• **Disaster Recovery Plan (DRP)**

A plan focused on recovering IT infrastructure, systems, and data after a disaster, including restoration procedures and recovery time objectives.

⚠️ ***Exam Trap:*** *DRP = recuperação técnica de TI após desastre. Não confunda com BCP, que é mais amplo e focado no negócio. DRP costuma vir após o BCP.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services company has a new requirement from executive leadership: all customer financial records must be protected with strong cryptography wherever they are stored or transmitted. The security architect is asked to create the document that states this mandatory, high-level requirement. Which type of document should be created?

A) Acceptable use policy

B) Security policy

C) Technical standard

D) Operational procedure

QUESTION 2 · EXAM SCENARIO

After approving the requirement that all sensitive data must be encrypted, the security team must specify approved algorithms, minimum key lengths, and protocols for servers, databases, and mobile devices. Which document should they publish?

A) Guideline

B) Procedure

C) Standard

D) Business continuity plan

QUESTION 3 · EXAM SCENARIO

A help desk team must ensure that every terminated employee's account is disabled within 30 minutes, including steps for verifying the ticket, contacting the manager, disabling the Active Directory account, revoking VPN access, and documenting completion. Which document should the team follow?

A) Acceptable use policy

B) Technical standard

C) Procedure

D) Guideline

QUESTION 4 · EXAM SCENARIO

A company wants to provide non-mandatory recommendations to employees about using strong unique passwords, enabling screen locks, and avoiding public Wi-Fi for sensitive work. These recommendations are not enforceable but reflect best practices. Which document type is most appropriate?

A) Policy

B) Standard

C) Procedure

D) Guideline

QUESTION 5 · EXAM SCENARIO

An employee installs a peer-to-peer file-sharing application on a corporate laptop to download movies and also uses the corporate email account to send personal investment advice to coworkers. HR asks which document most directly defines what personal activities are permitted on company systems. Which document should HR consult?

A) Disaster recovery plan

B) Acceptable use policy

C) Business continuity plan

D) Encryption standard

QUESTION 6 · EXAM SCENARIO

A regional hospital experiences a prolonged power outage. Clinical leaders need a documented approach for continuing patient admissions, paper-based medication tracking, and staffing rotation until power is restored, even if IT systems are unavailable. Which plan should they activate?

A) Disaster recovery plan

B) Incident response plan

C) Business continuity plan

D) Vulnerability management plan

QUESTION 7 · EXAM SCENARIO

A ransomware attack encrypts the primary data center. The IT team needs documented steps to rebuild servers, restore backups, validate data integrity, and fail over to the cloud site within the recovery time objective. Which plan should they use?

A) Business continuity plan

B) Disaster recovery plan

C) Acceptable use policy

D) Security awareness policy

QUESTION 8 · EXAM SCENARIO

A company's CIO wants to ensure that the organization can keep processing payroll and customer orders during a disruption, and has asked for a plan that identifies critical business functions, dependencies, and alternate manual workarounds. Which document is the CIO requesting?

A) Business continuity plan

B) Disaster recovery plan

C) Secure coding standard

D) Acceptable use policy

QUESTION 9 · EXAM SCENARIO

The security manager is revising governance documents. A document states that passwords must be at least 14 characters, MFA is required for remote access, and TLS 1.2 or higher must be used. The document does not explain how to configure systems. Which type of document is this?

A) Policy

B) Standard

C) Procedure

D) Guideline

QUESTION 10 · EXAM SCENARIO

An organization is drafting a document that outlines mandatory steps for responding to a lost company smartphone: notify security, remotely wipe the device, reset credentials, document the incident, and notify the privacy officer if sensitive data was involved. Which type of document is being drafted?

A) Guideline

B) Standard

C) Procedure

D) Business continuity plan

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Security policy

A security policy is the correct choice because it expresses management's mandatory high-level intent and principles. A technical standard would define specific algorithms or key lengths, a procedure would provide step-by-step instructions, and an acceptable use policy governs user behavior rather than data-protection requirements.

Question 2: Option C — Standard

A standard is correct because it provides specific, mandatory technical requirements that support a policy. A guideline is recommended rather than mandatory, a procedure is step-by-step execution, and a business continuity plan addresses maintaining business functions during disruptions.

Question 3: Option C — Procedure

A procedure is correct because it gives the ordered, step-by-step actions required to complete a specific operational task. An AUP defines allowed user behavior, a standard defines mandatory technical requirements, and a guideline offers non-mandatory recommendations.

Question 4: Option D — Guideline

A guideline is correct because it contains recommended best practices that are not mandatory. A policy is mandatory high-level intent, a standard contains mandatory technical requirements, and a procedure describes required step-by-step actions.

Question 5: Option B — Acceptable use policy

An acceptable use policy is correct because it defines what users may and may not do with organizational systems, networks, and data. DRP and BCP address recovery and continuity, while an encryption standard specifies cryptographic controls.

Question 6: Option C — Business continuity plan

A business continuity plan is correct because it focuses on sustaining critical business functions during a disruption. A disaster recovery plan focuses on restoring IT systems and data, while incident response and vulnerability management address security events and weaknesses.

Question 7: Option B — Disaster recovery plan

A disaster recovery plan is correct because it provides IT-focused procedures for restoring systems, data, and infrastructure after a disruptive event. A BCP maintains business functions during the event, while AUP and awareness policies address user behavior and training.

Question 8: Option A — Business continuity plan

A business continuity plan is correct because it identifies critical business functions and how to keep them operating during disruptions. A DRP is narrower and focuses on restoring IT infrastructure, while a secure coding standard and AUP address development controls and user behavior.

Question 9: Option B — Standard

A standard is correct because it contains specific, mandatory technical requirements such as password length, MFA, and TLS versions. A policy is broader intent, a procedure explains how to implement settings step by step, and a guideline is non-mandatory advice.

Question 10: Option C — Procedure

A procedure is correct because it specifies the ordered steps to perform a specific task. A guideline is optional advice, a standard defines mandatory technical requirements, and a BCP addresses continuity of business functions during disruptions.